

한국전력공사 상임감사위원

경고(주의) · 개선 · 권고 요구, 통보

제 목 [6] 업무용 계정 무단공유·유출 및 부여업무 미흡

관 계 부 서 정보보안처, ICT운영처, 서울본부, 부산울산본부, 경남본부

조 치 부 서 정보보안처, ICT운영처, 서울본부, 부산울산본부

내 용

1. 업무 개요

우리 회사 ICT업무 담당자는 계약상대자가 사내 전산망 이용이 필요한 경우 사내시스템 이용 필요성에 대해 검토한 후 1년 이내로 기한을 한정하여 승인¹⁾하고 있으며, ♥@ㄴ는 'ICT서비스데스크'의 요청사항을 확인하고 교체결과를 입력하기 위해 우리 회사로 SSO²⁾계정을 요청하고 있다.

2. 관계규정 및 판단기준

「정보보안업무기본지침」 제81조(비밀번호관리)와 제143조(정보통신보안 위규자 처리기준)에 따르면 사내시스템의 비밀번호의 경우 동일한 비밀번호를 여러 사람이 공유하여 사용하지 않아야 하고, 아이디, 비밀번호 등 중요정보를 타인, 타업체에 제공하지 않아야 한다.

1) 「정보보안업무기본지침」 제80조(보안관리) 및 「외부용역업체 보안관리방안」에 따라 시행

2) 통합인증(Single Sign-on), 한 번의 인증으로 사내시스템에 별도의 인증 없이 접근할 수 있는 인증 방법

또한 동 지침 제80조(계정관리)에 따르면 외부인에게 계정을 부여하지 아니 하되 업무상 불가피한 경우에는 처·실 및 사업소 보안담당자의 승인을 득한 후 시스템 관리책임자의 책임 하에 필요업무에 한해 특정기간 동안 접속토록 하는 등 보안조치 강구 후 허용하여야 한다.

‘ICT분야 업무위탁 용역’(이하 “위탁용역”이라 한다) 계약의 「외주용역사업 보안특약」 ‘보안위규 수준 정의’에 따르면 사용자 계정·비밀번호 등 정보시스템 접근권한 정보 등 누출금지대상 정보를 외부, 인터넷 등에 고의로 누출하지 않아야 하고 보안위규 사항이 발생한 경우 ‘보안위규 수준별 조치사항’에 따라 조치하여야 한다.

또한 동 특약 ‘협력사 보안관리 특수계약조건’에 따르면 계약상대자는 본 사업에 대한 하도급 계약을 체결할 경우 상기 조건 수준의 보안 준수사항을 하도급계약에 포함하여야 하며, 우리 회사는 하도급 계약업체에 의한 보안위규 사항 발생 시 계약상대자에게 연대책임을 부과할 수 있다.

따라서 우리 회사의 계약상대자인 ♥@ㄹ 직원과 하도급업체 직원은 ‘우리 회사 SSO계정의 아이디 및 비밀번호’(이하 “계정정보”라 한다)를 타인, 타업체와 공유하거나 누출하여서는 안되고, 우리 회사 직원은 업무상 불가피한 경우 외에는 외부인에게 우리 회사 SSO계정을 부여하여서는 안된다.

3. 감사결과 확인된 문제점

이에 감사기간 동안 서울본부, 부산울산본부 및 경남본부의 우리 회사 SSO 계정 정보 관리 적정여부를 점검한 결과, ① ICT업무 담당자가 ♥@ㄸ 하도급업체 직원들에게 우리 회사 사내시스템에 접근할 수 있는 계정을 부여(서울본부, 경남본부), ② ♥@ㄸ 하도급업체 직원들이 해당 계정정보를 서로 공유(서울본부), ③ ♥@ㄸ 직원이 우리 회사 직원에게 공유받은 계정을 하도급업체와 공유(부산울산본부)하여 우리 회사 SSO계정 정보를 부적정하게 관리한 사실이 확인되었다.

가. 하도급업체 직원 간 계정정보 무단 공유

서울본부 ☎%▼ 위탁용역 담당자 ▷☒*(4)은 사업소별 1개의 계정을 *◆♠ (하도급업체)에 발급하였는데 ☐☒♠의 경우 *◆♠ 직원 ○罽目에게 발급된 1개의 계정을 ○罽目, ▶♥@, ●◆■이 서로 공유하여 OA소모품 교체 관련 접수사항 확인, 대리신청 및 처리결과 입력 업무를 수행한 것으로 확인되었다.

상기 직원들은 우리 회사 SSO계정을 업무편의 사유로 공유하였고 이를 이용하여 OA소모품 일부를 대리 신청하였다고 진술하였는데, 이는 「외주용역사업 보안특약」의 보안위규 사항이므로 동 특약에 따라 ♥@ㄸ에 대해서는 위약벌 부과(부정당업자 등록 등) 검토가 필요하고, 서울본부 ▷☒*은 *◆♠ 직원 간의 계정 공유에 대한 관리가 소홀하였으므로 신분상 조치가 필요하다.

나. 우리 회사 직원-♡@ㄴ-하도급업체 간 계정정보 유출

부산울산본부 ICT업무 담당자 ●※ㄴ(4)은 2차 사업소 ICT실 내에서 정보통신망의 상태를 모니터링할 수 있는 단말장치인 콘솔PC용으로 발급한 SSO계정정보를 ♡@ㄴ ●@☎ ㄴ※ㄷ 직원들과 공유하였고, 이 중 ◁■●와 ○△ㄹ은 우리 회사에서 부여받은 콘솔PC의 계정을 ♣♠○ 직원 ☎◁△, ☎&ㄷ, ◇◆#, ◆※#과 공유하였다.

상기와 같이 부산울산본부 ●※ㄴ이 ♡@ㄴ ●@☎ ㄴ※ㄷ 직원들과 우리 회사 SSO계정을 공유한 행위는 「정보보안업무기본지침」을 위반한 것이고, ♡@ㄴ ●@☎ ㄴ※ㄷ 직원 ◁■●와 ○△ㄹ가 우리 회사 SSO계정을 ♣♠○ 직원 ☎◁△, ☎&ㄷ, ◇◆#, ◆※#과 공유한 행위는 「외주용역사업 보안특약」의 보안위규사항으로 동 특약에 따라 ♡@ㄴ에 대해서는 위약벌 부과(부정당업자 등록 등) 검토가 필요하고 ♡@ㄴ 직원과 계정을 공유한 부산울산본부 ●※ㄴ은 「정보보안업무기본지침」에 따라 신분상 조치가 필요하다.

다. 계정 부여절차 미준수

감사기간 동안 우리 회사의 SSO계정 하도급업체 부여 여부를 확인한 결과, 서울본부와 경남본부 모두 하도급업체에 ‘ICT서비스데스크’ 접속에 한정하여 계정을 발급하였다.

[표] 하도급업체 계정부여 현황(서울, 경남본부 2022년~2025년)

구 분	서울본부			경남본부		
	◆♠	신청자	합 계	◆▶	신청자	합 계

가명화

자료: 본부별 제출자료 재구성

그런데 「정보보안업무기본지침」에 따르면 우리 회사는 외부인에게 계정을 부여하지 아니하되 업무상 불가피한 경우에는 보안조치를 강구한 후 허용할 수 있음에도 위탁용역 담당자 서울본부 ▷☒*(4), ■◆□(4) 및 ○☎☆(4), 경남본부 &&&(4), □☒☒(4), ◆☎♥(4) 및 ☒※■(4)는 관련 내부품의 또는 ‘네트워크 보안관리시스템’상 기록 등 업무상 불가피성을 입증할 구체적인 근거를 제시하지 못하였으므로 위탁용역 담당자들은 하도급업체에 계정을 부여하면서 규정된 절차를 준수하지 않은 것으로 판단된다.

한편 정보보안처에서 운영 중인 ‘네트워크 보안관리시스템’³⁾에서 ICT업무 담당자가 외부인 계정을 신청할 경우 필요업무와 기간을 한정하고 사업소 보안 담당자의 승인을 받도록 되어 있으나, 아래 [그림]과 같이 ‘업무상 불가피한 사유’를 입력할 수 있는 입력란이 없음을 확인할 수 있었다.

3) 정보보안처가 사내망 접속, SSO아이디 발급, ICT설비 IP신청 등 업무를 위해 운영 중인 사내시스템

가명화

출처: 네트워크 보안관리시스템

이로 인해 ICT업무 담당자들이 규정에서 명시된 ‘업무상 불가피한 사유’에 대한 근거를 마련하기 위해서는 내부품의 등 비효율적인 단계를 거쳐야 하며, 규정을 인지하지 못한 담당자는 해당 절차가 필요한지 모르는 상태로 업무를 수행하게 된다.

이에 따라 정보보안처는 ‘업무상 불가피한 경우’에 대한 절차상 세부내역을 「정보보안업무기본지침」에 명시하고, 업무 담당자들에 대한 교육으로 외부인에 대한 계정부여 절차가 준수될 수 있도록 조치하여야 하고, ‘네트워크 보안관리 시스템’에 업무상 불가피성에 대한 기입란을 구현하여 업무가 익숙하지 않은 ICT업무 담당자들이 외부인에게 계정을 부여할 때 그 필요성에 대해 다시 한 번 생각할 수 있도록 시스템을 개선하여야 한다.

관련부서 등 의견 및 검토결과

가. 하도급업체 계정 유출 관련 의견 및 검토결과

부산울산본부 ●※冊(4)은 ♡@ㄴ ●@ㄴ ㄴ※ㄴ 직원들과 콘솔PC 계정을 공유한 것은 잘못된 일이나 본부 자체 보안점검에서 ♡@ㄴ의 2차 사업소 ICT실 내의 PC사용과 관련된 물리적 공간분리 지적사항의 조치를 위해 2차 사업소 ICT실의 ♡@ㄴ 계정을 삭제하고 본인이 2차 사업소별로 콘솔PC 계정을 발급받아 운영할 수 밖에 없었다고 진술하였다.

또한 ●※冊은 ㄴ%▼ 직원이 2차 사업소에 상주하지 않아 ♡@ㄴ에 설비의 위탁관리를 맡기고 있고 우리 회사 정보통신망의 상태를 ♡@ㄴ도 확인할 수 있어야 긴급상황 발생 시 신속한 대처를 할 수 있기 때문에 부득이 ♡@ㄴ와 콘솔PC계정을 공유할 수 밖에 없는 상황이었다고 소명하였다.

●※冊의 ♡@ㄴ 직원들과 계정공유는 본부 자체보안점검 지적사항의 근본적인 해결방안이 아닌 편법적인 해결방법으로 잘못된 행동이며, 우리 회사가 ♡@ㄴ에 설비의 위탁관리를 맡기고 있어 ♡@ㄴ와 콘솔PC용 계정을 공유할 수 밖에 없었다는 점, 계정공유와 하도급업체의 OA소모품 허위청구 간직접적인 인과관계를 규명하지 못하였다는 점 등을 감안한 신분상 조치가 필요하다고 판단된다.

나. 하도급업체 계정 부여 관련 의견 및 검토결과

서울본부 위탁용역 담당자들은 ‘네트워크 보안관리시스템’으로 하도급업체의 계정을 신청하면서 내부품의나 시스템상으로 업무상 불가피한 사유에 대해 명시하지 않았지만 다음과 같이 불가피성을 소명하였다.

▷☒*(4)은 ① 업무의 편의성과 시급성을 고려하여 관례적으로 하도급업체에 SSO계정을 발급하였고, ② 하도급업체가 단순 고장접수 확인용에만 사용하였다고 하였고, ③ 하도급업체의 역무가 명확하지 않다고 하였으며, ■◆□(4)은 ④ OA 소모품 업무를 명확히 수행(고장 처리한 하도급업체가 결과 입력까지 처리)하기 위해서는 하도급업체의 당사 사내시스템 접속이 불가피하고, ⑤ ♥@♣와 하도급업체가 동일한 업무를 수행한다고 판단하여 하도급업체가 업무처리 결과를 입력할 수 있도록 계정을 신청하였다고 답변하였다.

또한 정보보안처는 감사실에서 발송한 질문서⁴⁾에 대해 「정보보안업무기본지침」에 ‘업무상 불가피한 경우’라고 명시되어 있으나 해당 경우에 대한 세부내용이 없으므로 상기 지침 준수 여부를 판단할 수 없다고 답변하였다.

상기 답변을 고려하였을 때 정보보안처는 관련 업무 담당자들의 원활한 업무처리를 위해서 「정보보안업무기본지침」에 ‘업무상 불가피한 경우’에 대한 세부내용도 반영하여야 한다고 판단된다.

4) 감사실에서 2025. 7. 7. 보안위규 사항에 대해 질문서를 발송하였으며 정보보안처는 2025. 7. 8. 답변서를 회신

다만 ‘업무상 불가피한 경우’에 대해 명시하지 않고 외부인에게 계정을 발급한 우리 회사 직원에 대해 정보보안처의 답변을 감안한 신분상 조치가 필요하다고 판단된다.

조치할 사항

ICT운영처장은

- ① 우리 회사 계정을 하도급업체와 공유하는 행위를 막을 수 있는 근본적인 대책을 마련하여 주시기 바라며,(권고)
- ② 전사 직원을 대상으로 유사사례 재발방지 교육을 시행하여 주시기 바랍니다.(통보)

정보보안처장은

- ① 「정보보안업무기본지침」을 전면 재검토하여 외부인 계정 발급 및 관리에 관한 내용을 구체적으로 명시하여 주시기 바라며,(개선)
- ② ICT업무 담당자들이 외부인 계정을 신청할 때 ‘업무상 불가피성’에 대해 고려할 수 있도록 ‘네트워크 보안관리시스템’을 정비하여 주시기 바랍니다.(권고)

서울본부장은

- ① *◆♠(하도급업체) 직원 간의 계정공유를 관리하지 못한 ♥@♣ ▼◎● ♠▲□의 계정정보 관리 부적정에 대한 위약벌 부과(부정당업자 등록 등)를 검토하여 주시기 바라고,(통보)
- ② *◆♠ 직원 간의 계정공유에 대해 관리감독을 소홀히 한 책임이 있는 우리 회사 담당자에게 주의를 촉구하여 주시기 바랍니다.(주의)

부산울산본부장은

- ① 우리 회사 계정을 하도급업체와 공유한 ♡@ㄸ ●@☎ ㄸ※ㄹ 직원들의 보안
위규 행위에 대한 위약벌 부과(부정당업자 등록 등)를 검토하여 주시기 바라며,
(통보)
- ② ♡@ㄸ와 계정을 공유한 직원에게 ‘경고’를 촉구하고,(경고) 해당 직원에 대해
관리감독을 소홀히 한 책임이 있는 직상위자에게 ‘주의’를 촉구하여 주시기 바라며,
(주의)
- ③ 본부 자체 보안점검 결과를 준수하면서 ICT업무 담당자가 ♡@ㄸ 직원과
콘솔PC 계정을 공유하지 않도록 대책을 마련하여 주시기 바랍니다.(통보)

<조치요구사항 요약>

지적번호	행정상조치	재정상조치	신분상조치	관계부서	조치부서
6	개선 1 권고 2 통보 4	-	경고 1 주의 2	정보보안처 ICT운영처 서울본부 부산울산본부 경남본부	정보보안처 ICT운영처 서울본부 부산울산본부